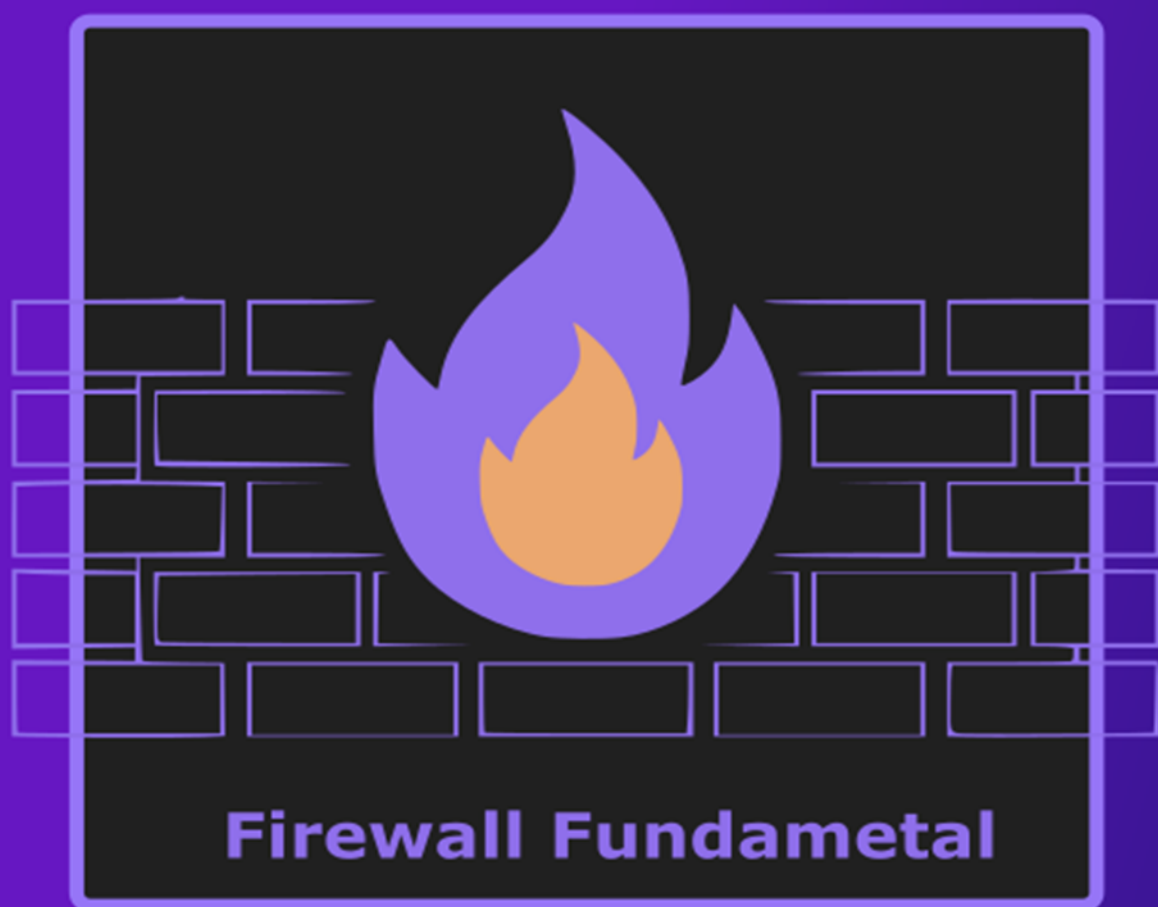




TryHackBox





موضوع :

مقدمات فایروال



تهیه شده توسط تیم TryHackBox

The Chaos



لینک زیر جهت حمایت از جامعه آموزش رایگان :

<https://daramet.com/TryHackBox>

ما را به دوستانتان معرفی کنید .

دیگر کانال ها و شبکه های اجتماعی ما را دنبال کنید:

کانال های تلگرام ما

آموزش تست نفوذ و Red Team :

[@TryHackBox](#)

رودمپ های مختلف:

[@TryHackBoxOfficial](#)

داستان های هک:

[@TryHackBoxStory](#)

آموزش برنامه نویسی:

[@TryCodeBox](#)

رادیو زیروپاد (پادکست ها):

[@RadioZeroPod](#)

اینستاگرام :

<http://www.instagram.com/TryHackBox>

یوتیوب:

<https://youtube.com/@tryhackbox>



فایروال چیست

فایروال یک سیستم امنیتی است که برای نظارت و فیلتر کردن ترافیک ورودی و خروجی شبکه بر اساس مجموعه‌ای از قوانین امنیتی از پیش تعریف شده طراحی شده است. این سیستم به عنوان یک مانع یا نقطه کنترل بین یک شبکه داخلی قابل اعتماد (مانند شبکه یک شرکت یا شبکه خانگی) و شبکه‌های خارجی غیرقابل اعتماد (مانند اینترنت) عمل می‌کند. هدف اصلی آن، اجازه دادن تنها به ارتباطات مجاز و امن و در عین حال مسدود کردن تهدیدات بالقوه و دسترسی‌های غیرمجاز است.

یک فایروال به عنوان یک سیستم امنیتی دیجیتال تعریف می‌شود که ترافیک داده‌ها بین یک دستگاه و اینترنت را زیر نظر گرفته و بر اساس قوانین امنیتی خاص، اجازه عبور داده‌ها را صادر کرده یا آن‌ها را مسدود می‌کند. هدف آن، محافظت از شبکه‌ها و دستگاه‌ها در برابر تهدیدات خارجی از طریق نظارت و فیلتر کردن ترافیک داده‌های ورودی و خروجی است. این سیستم را می‌توان به یک دیوار فیزیکی تشبیه کرد که یک مکان امن را از یک مکان ناامن جدا می‌سازد. در محیط دیجیتال مدرن، هدف اصلی یک فایروال، نظارت و تحلیل ترافیک داده‌های ورودی و خروجی و سپس اتخاذ تصمیم درباره اجازه یا مسدود کردن این داده‌ها است.

TryHackBox



یک فایروال صرفاً یک برنامه محافظتی نیست؛ بلکه یک سیستم امنیتی پیچیده و یکپارچه است که به طور هماهنگ برای محافظت از شبکه‌ها عمل می‌کند. این سیستم شامل مولفه‌های ضروری زیر است:

- **رابط کاربری (UI)** که به مدیران امکان مدیریت قوانین را می‌دهد.
 - **موتور قوانین (Rules Engine)** که سیاست‌های امنیتی را اعمال می‌کند.
 - **سیستم بازرسی stateful بسته‌های اطلاعاتی (Stateful Packet Inspection)** که ترافیک داده‌ها را تحلیل می‌کند.
 - **سیستم فیلترگذاری وب و برنامه‌ها (Web & Application Filtering)** برای کنترل دسترسی به وبسایت‌ها و برنامه‌ها.
 - **واحد ثبت وقایع و نظارت (Logs & Monitoring)** که فعالیت‌های امنیتی را برای بازبینی ثبت می‌کند.
- این واحدها به طور مستمر پایگاه داده تهدیدات و قوانین امنیتی را به روزرسانی می‌کنند تا در برابر آخرین تلاش‌های نفوذ و حملات شبکه مقابله نمایند.

فایروال چگونه کار می‌کند؟

فایروال با نظارت و تحلیل ترافیک داده‌ها بین شبکه‌ها عمل کرده و این داده‌ها را بر اساس مجموعه‌ای از قوانین از پیش تعریف شده فیلتر می‌کند. فایروال تمام ترافیک شبکه ورودی و خروجی رایانه شما را بر اساس قوانین داخلی و قوانین تعریف شده توسط کاربر کنترل می‌کند. این کار با اجازه دادن یا رد اتصالات شبکه انفرادی انجام می‌شود.



اصول پایه‌ای عملکرد فایروال

اصول اولیه عملکرد فایروال شامل نظارت بر ترافیک داده‌ها و اعمال قوانین امنیتی سختگیرانه است. فایروال بسته‌های داده‌ای را که واحدهای کوچکی از داده‌های انتقال‌یافته در شبکه‌ها هستند، بررسی می‌کند تا تصمیم بگیرد که آیا باید اجازه عبور داده شوند یا مسدود گردند.

مکانیزم تصمیم‌گیری فایروال

فایروال برای تعیین نحوه برخورد با ترافیک داده‌ها، به مجموعه‌ای از قوانین از پیش برنامه‌ریزی شده متکی است. این قوانین بر اساس معیارهای متعددی تعریف می‌شوند، از جمله:

• آدرس‌های IP مبدا و مقصد:

فایروال منبع و مقصد داده را بررسی می‌کند. اگر داده از یک منبع غیرقابل اعتماد یا مشکوک ارسال شده باشد، می‌تواند مسدود شود.

• شماره پورت‌ها:

فایروال پورت‌های استفاده شده در اتصال را بررسی کرده و از دسترسی به پورت‌های غیرمجاز برای جلوگیری از حملات سایبری ممانعت می‌کند.

• نوع پروتکل:

فایروال نوع پروتکل استفاده شده در اتصال، همچون HTTP یا FTP را نظارت می‌کند. اگر پروتکل ناشناخته یا مشکوک باشد، ممکن است مسدود شود.

• کلمات کلیدی/محتوای داده:

در فایروال‌های پیشرفته‌تر، داده‌های حاوی محتوای مشکوک یا ناخواسته می‌توانند مسدود شوند.



فرآیند دقیق بررسی بسته‌های اطلاعاتی

فایروال هر بسته داده را به طور جداگانه بررسی می‌کند و آن را با قوانین امنیتی مقایسه می‌نماید. این فرآیند شامل تجزیه و تحلیل هدر بسته، محتوای آن و زمینه اتصال است. فایروال‌های پیشرفته‌تر حتی قادرند الگوهای رفتاری مشکوک را در جریان داده‌ها شناسایی کنند.

اهمیت به‌روزرسانی مستمر قوانین

با توجه به پویایی تهدیدات سایبری، قوانین فایروال باید به طور منظم به‌روزرسانی شوند تا در برابر حملات جدید و تکنیک‌های نوین نفوذ مؤثر باشند. این به‌روزرسانی‌ها اغلب به صورت خودکار و از طریق سرویس‌های ابری ارائه می‌شوند.

انواع فایروال‌ها

فایروال‌ها با توجه به مکانیزم بازرسی و نوع استقرار به دسته‌های مختلفی تقسیم می‌شوند:

انواع فایروال بر اساس مکانیزم بازرسی

1. فایروال فیلترگذاری بسته‌ها

- قدیمی‌ترین و ساده‌ترین نوع فایروال
- در سطح بسته‌های داده عمل می‌کند
- بر اساس آدرس IP، پورت و پروتکل تصمیم‌گیری می‌کند
- محدودیت: قادر به بازرسی عمیق محتوا نیست

2. فایروال Stateful Inspection

- وضعیت اتصالات را پیگیری می‌کند
- بسته‌های بخشی از اتصالات معتبر را اجازه می‌دهد



- حفاظت بهتری نسبت به نوع قبلی ارائه می دهد

3. فایروال کاربردی

- بر روی برنامه ها و سرویس ها متمرکز است
- داده های برنامه را به طور کامل بازرسی می کند
- می تواند برنامه های غیرمجاز را مسدود کند

4. فایروال پروکسی

- به عنوان واسطه بین کاربران و شبکه خارجی عمل می کند
- از ارتباط مستقیم بین شبکه داخلی و اینترنت جلوگیری می کند
- آدرس های IP داخلی را مخفی می کند
- چالش : ممکن است باعث کاهش عملکرد شبکه شود

5. فایروال های نسل بعدی (NGFW)

- ترکیبی از قابلیت های فایروال سنتی و ویژگی های امنیتی پیشرفته
- شامل سیستم پیشگیری از نفوذ (IPS)
- قادر به اعمال سیاست ها در سطح برنامه
- از هوش مصنوعی و یادگیری ماشین استفاده می کند

انواع فایروال بر اساس نوع استقرار

1. فایروال سخت افزاری

- دستگاه های مستقل فیزیکی
- حفاظت قوی برای کل شبکه



- مناسب برای شبکه‌های بزرگ

2. فایروال نرم‌افزاری

- بر روی دستگاه‌های فردی نصب می‌شود
- مناسب برای محافظت از دستگاه‌های خاص

- مثال : Windows Firewall

3. فایروال ابری

- به عنوان سرویس در محیط‌های ابری ارائه می‌شود
- انعطاف‌پذیر و مقیاس‌پذیر
- مناسب برای محیط‌های ابری پویا

4. فایروال هیبریدی

- ترکیبی از مزایای فایروال فیزیکی، نرم‌افزاری و ابری
- سطح بالاتری از امنیت را ارائه می‌دهد

TryHackBox



جدول ۱: مقایسه انواع اصلی فایروال‌ها

فایروال نسل بعدی (NGFW)	فایروال پروکسی	فایروال لایه کاربرد	فایروال بازرسی حالت‌دار	فایروال فیلترگذاری بسته	معیار
لایه‌های ۳ تا ۷	لایه ۷	لایه ۷	لایه‌های ۳ و ۴	لایه ۳	لایه عملیاتی مدل OSI

مکانیزم بازرسی

بازرسی عمیق بسته، IPS، کنترل برنامه	واسط بین کاربر و سرویس	بازرسی محتوای برنامه و پروتکل‌ها	ردیابی حالت اتصال و تحلیل محتوا	بازرسی بسته‌های مجزا IP، پورت، پروتکل	ویژگی‌های کلیدی
IPS، ضد بدافزار، هوش مصنوعی، VPN، SD-WAN	مخفی‌سازی IP، کش، کنترل دقیق	بازرسی محتوای برنامه، مسدودسازی برنامه	ردیابی اتصال، امنیت بهتر	فیلترینگ ساده مبتنی بر ACLs	
محافظت جامع، تشخیص تهدیدات پیشرفته، یکپارچه‌سازی	امنیت بهبودیافته (بدون اتصال مستقیم)، حریم خصوصی بهتر، کنترل دقیق	کنترل دقیق برنامه، تشخیص تهدیدات پیشرفته	امنیت بالاتر از فیلترینگ بسته، عملکرد خوب	ساده، سبک، کم‌هزینه	مزایا
			بازرسی نکردن محتوای عمیق برنامه	امنیت محدود، عدم بازرسی محتوا، آسیب‌پذیر در برابر جعل	محدودیت‌ها



قوانین در فایروال‌ها

یک فایروال به شما کنترل کاملی بر ترافیک شبکه می‌دهد. اگرچه فایروال ترافیک را بر اساس قوانین داخلی خود فیلتر می‌کند، اما می‌توان قوانین سفارشی‌شده‌ای برای شبکه‌های مختلف تعریف کرد.

اجزای اصلی قوانین فایروال:

- آدرس مبدأ: آدرس IP دستگاه مبدأ ترافیک
- آدرس مقصد: آدرس IP دستگاه دریافت‌کننده داده
- پورت: شماره پورت مربوط به ترافیک
- پروتکل: پروتکل مورد استفاده در ارتباط
- اقدام: عملی که بروی شناسایی ترافیک انجام می‌شود
- جهت: اعمال قانون بر ترافیک ورودی یا خروجی

انواع اقدامات (Actions)

1. اجازه (Allow)

- اجازه دادن به ترافیک مشخص‌شده در قانون
- مثال: ایجاد قانون برای اجازه تمام ترافیک خروجی از شبکه برای پورت 80

2. رد (Deny)

- مسدود کردن ترافیک مشخص‌شده در قانون
- اساسی برای تیم امنیتی برای مسدود کردن ترافیک از آدرس‌های IP مخرب
- مثال: ایجاد قانون برای رد تمام ترافیک ورودی مشکوک



3. انتقال (Forward)

- هدایت ترافیک به بخش دیگری از شبکه
- مربوط به فایروال‌هایی که قابلیت مسیریابی دارند
- مثال: انتقال تمام ترافیک ورودی پورت 80 به سرور وب 192.168.1.8

جهت‌دار بودن قوانین:

قوانین ورودی (Inbound Rules)

- اعمال روی ترافیک ورودی
- مثال: اجازه ترافیک HTTP ورودی (پورت 80) به سرور وب

قوانین خروجی (Outbound Rules)

- اعمال روی ترافیک خروجی
- مثال: مسدود کردن تمام ترافیک SMTP خروجی (پورت 25) از همه دستگاه‌ها به جز سرور ایمیل

قوانین انتقال (Forward Rules)

- برای هدایت ترافیک در داخل شبکه
- مثال: ایجاد قانون برای هدایت ترافیک HTTP ورودی به سرور وب داخل شبکه

این قوانین به مدیران شبکه امکان می‌دهند امنیت شبکه را به طور دقیق و متناسب با نیازهای خاص خود پیاده‌سازی کنند.